

API CANON

2026-03-18

Dexter Hadley, MD/PhD

Hadley Lab CANONIC

Abstract

API is the network surface for COIN. Every endpoint authenticated. Every response governed.

hadleylab.org Governed Research. Every claim cited.

Contents

1 Constraints

1. Constraints

1

- MUST: Authenticate via IDENTITY tokens (Bearer authentication)
- MUST: Wrap vault commands never duplicate economic data
- MUST: Serve public views (SHOP, econ) without authentication
- MUST: Validate request shape before dispatching to downstream
- MUST: Return JSON responses with governed schemas
- MUST: Restrict CORS to governed origins never wildcard
- MUST: Rate-limit all endpoints protect upstream providers
- MUST: Retry Stripe and GitHub calls with exponential backoff
- MUST: Handle SIGTERM drain in-flight requests before shutdown
- MUST: Log all requests as structured JSON to stdout
- MUST NOT: Expose VAULT internals (private balances, keys)
- MUST NOT: Accept unsigned privileged actions (after rotation)
- MUST NOT: Store state beyond CONFIG all truth lives in the database